FUTURE INTERNS TASK 3

API Security Risk Analysis

Vulnerability Assessment & Remediation Report

JSONPlaceholder Demo API

PREPARED BY
Idowu Popoola

DATE
15 April 2026

CLASSIFICATION
Confidential

ASSESSMENT OVERVIEW

Executive Summary & Methodology

SUMMARY

This report present a passive security assessment of the JSONPlaceheader public demo API at:

https://jsonplaceho;der.typicode.com

The assessment focused on identifying API-Level security weakness including unauthenticated across,excessive data expose and missing rate limiting controls

Multiple API risks identified

SCOPE

Authorised testing strictly limited to the primary domain only.

africanfreefirecommunity.com

RULES OF ENGAGEMENT

Testing was 100% passive to ensure zero disruption to availability

TOOLS UTILIZED

Postman

API endpoint querying & response inspection

OWASP ZAP

Network traffic & response header analysis

Browser DevTools

Public demo API used as safe test target

IDENTIFIED VULNERABILITIES

Findings & Risk Classification

2 HIGH | 1 MEDIUM | 1 LOW | 4 TOTAL FINDINGS

Detailed analysis provided for MEDIUM risks

#	FINDING	RISK	IMPACT SUMMARY	STATUS
01	**Unauthenticated Access to User Data** All /users endpoints return full PII with no token or key required Endpoint: Get /users, Get /users/1	HIGH	Full user PII exposed without credentials	NEEDS FIX
02	**Excessive Data Exposure** API returns full object including fields not needed by the client Endpoint: GET /users — returns name, email, phone, address, company	HIGH	Sensitive fields exposed beyond what is required	NEEDS FIX
03	**Missing Rate Limiting** API accepts unlimited request with no throttling or request cap Tested: 100+ rapid requests to GET /posts — all accepted without restriction	MEDIUM	Vulnerable to abuse, scraping & Dos attacks	NEEDS FIX
04	**Missing Rate Limiting** API responses lack X-Content-Type-Options and Content-Security-Policy Observed in response headers via Postman & Browser DevTools	LOW	Browser-level protection weakened	MONITOR

High — Immediate action required | Medium — Fix within 30 days | Low — Best practice improvement

FINDING 01 OF 02 — HIGH RISK

Unauthenticated Access to User Data

01 | MEDIUM | NEEDS FIX | Endpoint: GET /users

WHAT IS IT?

The API allows any user to retrieve full user records without any authentication token, API key, or login credentials.

GET /users return all records with zero authorization required

BUSINESS IMPACT

Any attacker can harvest full user PII — names, emails,phone numbers and addresses without any credentials.

PII Exposure / data Breach Risk

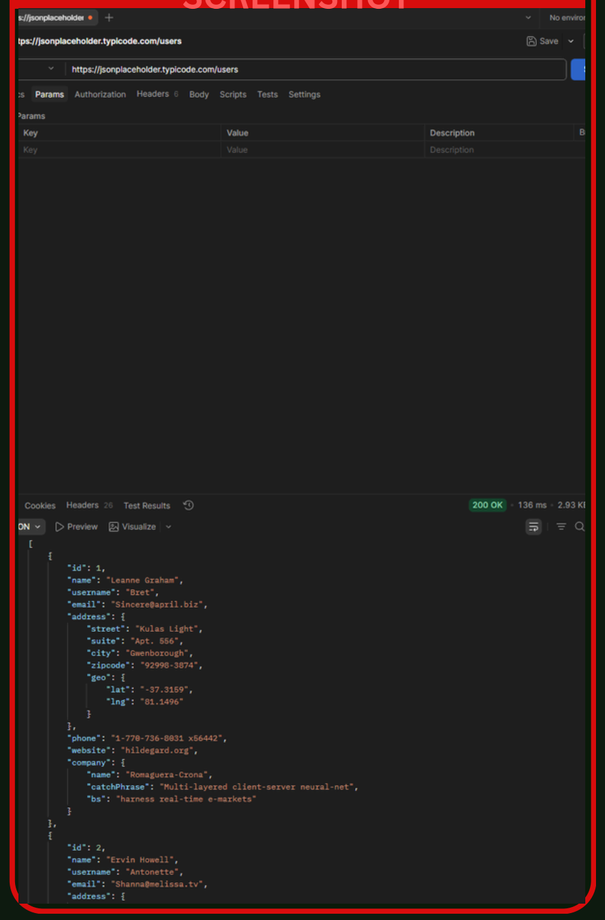
REMEDIATION

Implement authentication on all user-related endpoints:
Authorization: bearer <token>

Required on all /users routes

Use OAuth 2.0 or API key validation before returning data

EVIDENCE - POSTMAN SCREENSHOT



FINDING 02 OF 02 — HIGH RISK

Excessive Data Exposure

01 | MEDIUM | NEEDS FIX | Endpoint: GET /users/1

WHAT IS IT?

The API returns far more data than necessary. A single user request exposes: name, username,email, phone, address & company.

API should return only what the client specifically needs.

BUSINESS IMPACT

Attackers receive a complete profile on every user — enabling targeted phishing, identity theft and social engineering attacks.

PII Exposure / data Breach Risk

REMEDIATION

Apply field filtering — return only what the client needs:

GET /users/1?fields=name,email

Return only requested fields

Follow API principle of least privilege for data responses

EVIDENCE - POSTMAN SCREENSHOT


```
"id": 1,
"name": "Leanne Graham",
"username": "Bret",
"email": "Sincere@april.biz",
"address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
        "lat": "-37.3159",
        "lng": "81.1496"
    }
```

FINAL SECTION

Recommendations & Conclusion

PRIORITY ACTION PLAN

Ordered by urgency

1	**Implement authentication on all users-facing API endpoints** Require Bearer token or API key – no data returned without credentials	HIGH	Immediate priority
2	**Apply field filtering – return only data the client explicitly needs** Implement response shaping so sensitive field are excluded by default	HIGH	Immediate priority
3	**Implement rate limiting on all API endpoints** Cap request per IP per minute - return 429 Many Request when exceeded	MEDIUM	Within 30 days
4	**Add security headers to all API endpoints** Include X-content-Type-Option and Content-Security-Policy on every response	LOW	Next maintenance cycle

CONCLUSION

The JSONPlaceholder API assessment revealed four security weaknesses — two of which are rated High severity. The mostcritical issues are the complete absence of authentication on user endpoints and excessive data exposure, both of whichcould enable mass PII harvesting by any external actor. These findings are representative of the OWASP API SecurityTop 10 and are common in real-world APIs that have not undergone a formal security review

OVERALL SECURITY RATING

POOR

Auth + Rate limiting will elevate to FAIR